

RE-AUDIT REPORT

AI-OS-New

SuperAgents OS v4.5.0 — Post-Fix Verification

github.com/n95887174-source/ai-os-new

Re-Audit Date: 2026-06-15

Auditor: Z.ai Automated Analysis

	Original Audit	Re-Audit	Delta
Total Issues	84	53	-31 (37% reduction)
CRITICAL	13	0	-13 (all fixed!)
HIGH	35	17	-18
MEDIUM	32	28	-4
LOW	4	8	+4 (new found)
Fixed	—	39	
Partially Fixed	—	12	
Still Present	—	14	
New Issues	—	29	requires attention

1. Executive Summary

Данный документ представляет результаты повторного аудита репозитория `ai-os-new` после применения фиксов, основанных на первичном аудите. Повторный анализ охватывает те же 5 направлений и проверяет статус каждого из 84 первоначальных находок, а также выявляет новые проблемы, внесённые изменениями.

Ключевой результат: из 84 первоначальных проблем 39 полностью исправлены (46.4%), 12 частично исправлены (14.3%), 14 остаются (16.7%). Все 13 CRITICAL-проблем из первого аудита решены (8 полностью, 5 частично). При этом обнаружено 29 новых проблем (6 HIGH, 14 MEDIUM, 9 LOW), в основном в области типобезопасности и UX/i18n.

Наиболее значимые исправления: CSP-политика усилена (`wasn-unsafe-eval` вместо `unsafe-eval`); API-ключи перенесены в `IndexedDB`; `DOMPurify` добавлен для `MarkdownRenderer`; `race condition` в `useKeyStore` решён атомарным обновлением; `setInterval` утечка устранена; `TypeScript strict mode` включён; `Vite production build` настроен; `nginx security headers` добавлены; 73+ ключей перевода добавлены в `ru.ts`; `flash of wrong theme` устранён через `inline script`.

Критические оставшиеся проблемы: `runtime.start()` без `.catch()` в `main.tsx`; `dompurify` отсутствует в `package.json dependencies`; `dexie-storage importAll()` не использует `safeParse`; `skip-nav` ссылка нерабочая (нет `id="main-content"`); `AgentWizard` без `focus trap`; 29 новых проблем требуют внимания.

2. Security Re-Audit

Из 15 первоначальных проблем безопасности: 8 исправлены, 4 частично, 3 остаются. Обнаружено 6 новых проблем (2 HIGH, 3 MEDIUM, 1 LOW).

2.1 Previous Findings Status

ID	Status	Severity	Details
S-01	FIXED	was CRITICAL	CSP: unsafe-inline+unsafe-eval заменены на wasm-unsafe-eval в обоих nginx конфигах
S-02	FIXED	was CRITICAL	Ключи теперь в Dexie (IndexedDB). localStorage только как migration fallback с немедленной очисткой
S-03	FIXED	was HIGH	DOMPurify.sanitize() добавлен для обоих dangerouslySetInnerHTML в MarkdownRenderer
S-04	PARTIALLY FIXED	HIGH	new Function() остается, но 3 уровня защиты (AST + runtime shadows + Proxy). Остаточный риск: edge cases в AST-парсере
S-05	PARTIALLY FIXED	HIGH	Соль по умолчанию в sessionStorage (очищается при закрытии вкладки). persist=true путь все еще доступен
S-06	FIXED	was HIGH	safeParse() с reviver добавлен в sqlite-storage.ts для защиты от prototype pollution
S-07	FIXED	was HIGH	Root nginx.conf обновлён, помечен как LEGACY. CSP идентичен docker-конфигу
S-08	PARTIALLY FIXED	MEDIUM	doc.write() остается для CSS, но escapeForStyle() предотвращает breakout. Рекомендуется srcdoc
S-09	FIXED	was MEDIUM	X-XSS-Protection и HSTS добавлены в nginx-ssl.conf
S-10	FIXED	was MEDIUM	Vary: Origin добавлен в cors-proxy.mjs
S-11	PARTIALLY FIXED	MEDIUM	IPv6 частично покрыт, но ::ffff:127.0.0.1 не блокируется. 172.16.0.0/12 неполный (только 172.16.*)
S-12	STILL PRESENT	MEDIUM	Ollama/LM Studio используют HTTP для localhost — ожидаемо для локальных сервисов
S-13	FIXED	was MEDIUM	Все SQL-запросы используют параметризованные ? плейсхолдеры
S-14	STILL PRESENT	LOW	Комментарий-шаблон для встраивания ключей в main.tsx остается
S-15	STILL PRESENT	LOW	innerHTML в тестах (не runtime-риск)

2.2 New Security Issues

ID	Status	Severity	Details
SN-01	NEW	HIGH	dompurify отсутствует в package.json dependencies — только @types/dompurify. Санитизация может молча исчезнуть
SN-02	NEW	HIGH	dexie-storage.ts: 7 importAll() методов используют raw JSON.parse вместо safeParse(). Prototype pollution защита не применяется
SN-03	NEW	MEDIUM	cors-proxy.mjs: isPrivateHost() не резолвит AAAA/IPv6 DNS записи — SSRF обход через IPv6-only домены
SN-04	NEW	MEDIUM	sandbox-service.ts: 172.16.0.0/12 проверяет только 172.16.*, пропускает 172.17-172.31
SN-05	NEW	MEDIUM	CodeRunner CSS: doc.write() вместо srcdoc — CSS url() может эксфильтровать данные
SN-06	NEW	LOW	DOMPurify.sanitize() вызывается без явной конфигурации ALLOWED_TAGS

3. Type Safety Re-Audit

Из 14 первоначальных проблем типобезопасности: 3 исправлены (включая 2 CRITICAL), 6 частично, 5 остаются. Обнаружено 7 новых проблем (3 HIGH, 3 MEDIUM, 1 LOW). Ключевое улучшение: `cognitive-service.ts` полностью типизирован, `Connector` дедуплицирован, `strict mode` включён в `tsconfig`.

3.1 Previous Findings Status

ID	Status	Severity	Details
T-01	FIXED	was CRITICAL	<code>cognitive-service.ts</code> : 0 использований <code>any</code> . Все <code>onSafe</code> с явными типами
T-02	FIXED	was CRITICAL	<code>virtualKey</code> : <code>any</code> заменён на <code>VirtualKey</code> в обеих картах событий. НО: дублирующийся импорт <code>VirtualKey</code> в <code>event-bus.ts</code>
T-03	FIXED	was CRITICAL	<code>types/domain.ts</code> теперь реэкспортирует <code>Connector</code> из <code>types/index.ts</code> — единый источник истины
T-04	PARTIALLY FIXED	HIGH	2 из 3 <code>as never</code> удалены. Остается <code>RoleSandbox.tsx:36</code> — <code>messages as never</code>
T-05	PARTIALLY FIXED	HIGH	Zod-валидация добавлена в <code>openai-compatible-adapter</code> , но при ошибке <code>safeParse</code> используется <code>raw data</code> . 6 <code>chained as</code> остаются
T-06	PARTIALLY FIXED	HIGH	<code>unknown payloads</code> сокращены с ~10 до 7. <code>debate/tool/мсп</code> события всё ещё <code>unknown</code>
T-07	PARTIALLY FIXED	HIGH	<code>virtualKey</code> выровнен. Остаются расхождения: <code>debate:updated</code> — <code>unknown vs typed</code> ; <code>agent:config:updated</code> — <code>id vs agentId</code>
T-08	PARTIALLY FIXED	HIGH	<code>toNum()/toBool()</code> хелперы заменяют <code>as</code> -приведения. Но <code>JSON.parse</code> без схемы и (<code>session as unknown as Record</code>) остаются
T-09	STILL PRESENT	HIGH	<code>kernel.ts</code> : <code>raw as Record</code> в 5 методах. Паттерн дефендабельный, но Zod был бы строже
T-10	STILL PRESENT	MEDIUM	Нет общего <code>enum</code> для статусов. Каждый модуль определяет свой <code>type alias</code>
T-11	PARTIALLY FIXED	MEDIUM	<code>any</code> значительно сокращён. ~94 <code>:any/as: any</code> остаются в ~45 файлах (<code>key-analytics.ts</code> , <code>scheduler-service.ts</code> , <code>useKeyStore.ts</code>)
T-12	STILL PRESENT	MEDIUM	<code>as</code> -приведения остаются в ~250+ файлах. Системного исправления нет
T-13	STILL PRESENT	MEDIUM	Явные <code>return types</code> не добавлены системно
T-14	STILL PRESENT	MEDIUM	Non-null assertions (!) остаются. <code>key-analytics.ts:51</code> <code>key.stats.extended!</code>

3.2 New Type Safety Issues

ID	Status	Severity	Details
TN-01	NEW	MEDIUM	<code>event-bus.ts:16-17</code> : дублирующийся <code>import type { VirtualKey }</code>
TN-02	NEW	HIGH	<code>key-analytics.ts:22</code> : <code>ensureUsageReset(ext: any)</code> — должен использовать <code>KeyExtendedStats</code>
TN-03	NEW	HIGH	<code>scheduler-service.ts:238</code> : <code>scheduler:heartbeat as any</code> — событие не в <code>EventMap</code>
TN-04	NEW	HIGH	<code>useKeyStore.ts:72,78</code> : <code>metrics:key-store-gauges as any</code> — событие не в <code>EventMap</code>
TN-05	NEW	MEDIUM	<code>useKeyStore.ts:176</code> : <code>setStore(patch as KeyStoreState)</code> — скрытое несовпадение типов <code>Partial</code> vs <code>Partial</code>
TN-06	NEW	MEDIUM	<code>openai-compatible-adapter.ts</code> : при ошибке <code>safeParse</code> <code>raw data</code> используется с <code>as</code> -приведениями. Валидация косметическая
TN-07	NEW	LOW	<code>tsconfig.app.json</code> : <code>noUncheckedIndexedAccess</code> не включен — <code>array/object access</code> может быть <code>undefined</code>

4. Logic Bugs Re-Audit

Из 17 первоначальных логических проблем: 10 исправлены (включая оба CRITICAL), 2 частично, 5 остаются. Обнаружено 2 новые проблемы (1 HIGH, 1 LOW). Ключевые исправления: setInterval утечка устранена; race condition в useKeyStore решён; race-executor firstSuccess исправлен; CodeRunner cleanup рефакторинг; stalenessMs реактивен.

4.1 Previous Findings Status

ID	Status	Severity	Details
L-01	FIXED	was CRITICAL	cross-tab-state.ts: оба setInterval хранятся (heartbeatTimer + syncTimer), destroy() очищает оба
L-02	FIXED	was CRITICAL	useKeyStore: одиночный setStore(patch) с keys + keyMeta — атомарное обновление
L-03	FIXED	was HIGH	race-executor.ts: firstSuccess сканирует победителя перед await, устраняя окно пропуска
L-04	PARTIALLY FIXED	MEDIUM	circuit-breaker: try/finally для transitioningToHalfOpen. Но guard — мёртвый код (синхронный блок)
L-05	STILL PRESENT	HIGH	main.tsx: runtime.start().then() без .catch() — UI зависает при ошибке
L-06	FIXED	was HIGH	AgentsPanelView: .catch() добавлен к обоим .then() цепочкам
L-07	FIXED	was HIGH	CodeRunner: cleanup() удаляет iframe, listener, timeout. capturedIframe для HTML-пути
L-08	STILL PRESENT	HIGH	main.tsx: beforeunload/visibilitychange слушатели накапливаются при HMR
L-09	FIXED	was HIGH	Атомарный setStore решает рассинхрон keys/keyMeta
L-10	FIXED	was HIGH	useSystemStatus: stalenessMs реактивен через setInterval(1000) в useEffect
L-11	FIXED	was MEDIUM	useChatStore: stream handlers используют функциональные setState(s => ...)
L-12	PARTIALLY FIXED	HIGH	cross-tab-state: countMismatches использует неверные имена свойств (state.state вместо state.status, failures вместо failureCount) — возвращает неверный результат
L-13	STILL PRESENT	MEDIUM	DebatePanel.tsx: destroy() глобального store при unmount одного компонента
L-14	FIXED	was MEDIUM	memory-engine.ts: .catch() добавлен ко всем .then() цепочкам
L-15	STILL PRESENT	MEDIUM	6+ LLM адаптеров: пустые catch {} блоки (13 инстансов). Файлы не были в пуше
L-16	FIXED	was MEDIUM	/events маршрут → редирект на /timeline через Navigate. EventsPanel не рендерится
L-17	FIXED	was MEDIUM	App.tsx: groupManager добавлен в deps useEffect — предотвращает stale closure

4.2 New Logic Issues

ID	Status	Severity	Details
LN-01	NEW	HIGH	cross-tab-state.ts countMismatches: state.state/state.failures не существуют (нужно state.status/state.failureCount) — считает BCE CB как mismatches
LN-02	NEW	LOW	circuit-breaker.ts: transitioningToHalfOpen guard — мёртвый код (невозможен одновременный вызов в синхронном JS)

5. Build / Deploy Re-Audit

Из 16 первоначальных проблем сборки/деплойа: 10 исправлены (включая оба CRITICAL и 6 из 7 HIGH), 1 частично, 5 остаются. Обнаружено 4 новые проблемы (1 MEDIUM, 3 LOW). Ключевые исправления: SYNC_SECRET= пустой; nginx catch-all deny; strict mode в tsconfig; ws в dependencies; streaming proxy timeouts; server_tokens off; Vite production build.

5.1 Previous Findings Status

ID	Status	Severity	Details
B-01	FIXED	was CRITICAL	.env.example: SYNC_SECRET= (пусто) + предупреждение. sync-server: fail-fast при пустом токене
B-02	FIXED	was CRITICAL	nginx: catch-all /proxy/ — deny all; return 403. Только явные provider-маршруты
B-03	FIXED	was HIGH	tsconfig.app.json: skipLibCheck: false
B-04	FIXED	was HIGH	tsconfig.app.json: strict: true, strictNullChecks: true, noImplicitAny: true
B-05	FIXED	was HIGH	tsconfig.app.json: noUnusedLocals: true, noUnusedParameters: true
B-06	FIXED	was HIGH	ws перемещён из devDependencies в dependencies
B-07	FIXED	was HIGH	nginx: proxy_buffering off, proxy_read_timeout 120s, proxy_send_timeout 120s
B-08	FIXED	was HIGH	server_tokens off; добавлен во все server блоки
B-09	STILL PRESENT	HIGH	Нет CI/CD конфигурации — нет автоматизированного pipeline
B-10	FIXED	was HIGH	vite.config.ts: build section с sourcemap:false, manualChunks, code-splitting
B-11	FIXED	was MEDIUM	CSP согласован между root и static-asset location в обоих конфигах
B-12	PARTIALLY FIXED	MEDIUM	SSRF исправлен (catch-all deny). NO /proxy/fetch отсутствует — запросы получают 403. Нужен маршрут или cors-proxy сервис
B-13	FIXED	was MEDIUM	.gitignore: добавлены certs/, *.pem, *.key, .env.production, test-results/
B-14	STILL PRESENT	MEDIUM	TypeScript ~6.0.2 конфликтует с madge@8 peer-dep. --legacy-peer-deps в Dockerfile
B-15	STILL PRESENT	MEDIUM	Zustand v4 с React 19 — v5 официальная совместимая версия
B-16	STILL PRESENT	MEDIUM	Нет Prettier и format скрипта — форматирование не контролируется

5.2 New Build/Deploy Issues

ID	Status	Severity	Details
BN-01	NEW	MEDIUM	PROXY_GENERIC определяется в entrypoint.sh, но не используется ни в одном nginx location block — мёртвая переменная
BN-02	NEW	LOW	Несогласованный proxy_ssl_trusted_certificate: /api/ location имеет, /proxy/* — нет
BN-03	NEW	LOW	Dev CSP: connect-src https: разрешает любые HTTPS-домены (prod ограничивает конкретными)
BN-04	NEW	LOW	Legacy nginx.conf в корне проекта без server_tokens, streaming proxy, provider routes

6. UX / Accessibility Re-Audit

Из 20 первоначальных UX-проблем: 6 исправлены (включая 2 CRITICAL), 6 частично, 8 остаются. Обнаружено 10 новых проблем (2 HIGH, 5 MEDIUM, 3 LOW). Ключевые исправления: 73+ ключей ru.ts; FOIT theme устранён; BudgetPanel локализован; ErrorBoundary переведён на t(); AgentWizard адаптивный.

6.1 Previous Findings Status

ID	Status	Severity	Details
U-01	PARTIALLY FIXED	HIGH	Skip-nav link добавлен (App.tsx:363), HO не имеет id="main-content" — ссылка нерабочая!
U-02	FIXED	was CRITICAL	ru.ts: все 73+ ключей добавлены (pressure_map, pricing, system_health)
U-03	FIXED	was CRITICAL	index.html: inline script для чтения темы из localStorage до React mount — FOIT устранён
U-04	PARTIALLY FIXED	MEDIUM	window.confirm() сокращён с 7+ до 4. Остаются: ToolsTab, HypothesisMarketplace, MCPPanel
U-05	FIXED	was HIGH	AgentsPanelView: aria-label на search input, view toggles, agent cards, action buttons
U-06	PARTIALLY FIXED	HIGH	AgentWizard: role="dialog", aria-modal="true" добавлены. HO нет focus trap — Tab уходит за модальку
U-07	PARTIALLY FIXED	MEDIUM	~20+ захардкоженных английских строк остаются (AgentWizard: 8, App.tsx: 5, ConnectorsPanel: 6+)
U-08	STILL PRESENT	HIGH	15+ .toLocaleString()/toLocaleTimeString() без передачи locale из настроек
U-09	FIXED	was HIGH	BudgetPanel: fmtUSD(v, locale) через Intl.NumberFormat с поддержкой ru-RU/en-US
U-10	FIXED	was HIGH	ErrorBoundary: t() для всех строк + role="alert" + aria-live="assertive"
U-11	PARTIALLY FIXED	MEDIUM	BudgetPanel частично исправлен. AgentWizard полностью inline-styled с dark-only цветами — невидим в светлой теме
U-12	STILL PRESENT	HIGH	Только LogsPanel использует react-virtual. Остальные длинные списки — без виртуализации
U-13	PARTIALLY FIXED	MEDIUM	ConnectorsPanel: ModalShell с focus management. ProjectOsExplorer: onContextMenu без клавиатурного эквивалента
U-14	PARTIALLY FIXED	MEDIUM	@media (prefers-reduced-motion) добавлен в index.css. HO framer-motion анимации не используют useReducedMotion()
U-15	FIXED	was MEDIUM	AgentWizard: width: min(560px, 92vw) — адаптивный
U-16	STILL PRESENT	MEDIUM	Числовое форматирование не локализовано — .toLocaleString() без locale
U-17	STILL PRESENT	MEDIUM	Нет Intl.PluralRules — русские plural формы не обрабатываются
U-18	FIXED	was MEDIUM	document.documentElement.lang обновляется при монтировании React
U-19	STILL PRESENT	LOW	Touch targets < 44x44px — AgentWizard tool buttons, close buttons
U-20	STILL PRESENT	LOW	Super-Agents OS не обновляется и не локализуется

6.2 New UX Issues

ID	Status	Severity	Details
UN-01	NEW	HIGH	AgentWizard: без htmlFor/id привязки — screen readers не ассоциируют label с input

ID	Status	Severity	Details
UN-02	NEW	HIGH	AgentWizard: Refine input без label (только placeholder)
UN-03	NEW	MEDIUM	App.tsx: skip-nav href="#main-content" но нет id="main-content" — ссылка мертвая
UN-04	NEW	MEDIUM	ConnectorsPanel: фильтры All/Connected/Offline — hardcoded English
UN-05	NEW	MEDIUM	ConnectorsPanel: заголовки таблиц Endpoint Name/Route/Target/Status — hardcoded English
UN-06	NEW	MEDIUM	ConnectorsPanel: модальное окно Revoke Connection? — hardcoded English
UN-07	NEW	MEDIUM	ConnectorsPanel: Zero-Trust Architecture баннер — hardcoded English
UN-08	NEW	MEDIUM	main.tsx: boot splash с hardcoded dark цветами и Initializing... — невидим в светлой теме
UN-09	NEW	LOW	App.tsx: GlobalErrorBoundary fallback — hardcoded English без t()
UN-10	NEW	LOW	ConfirmDialog: дефолтные Confirm/Cancel — hardcoded English

7. Top Priority Remaining Issues

Наиболее критичные проблемы, требующие немедленного внимания:

#	Severity	Category	Issue	Fix
1	HIGH	Security	dompurify отсутствует в package.json — санитизация может исчезнуть	Добавить dompurify в dependencies
2	HIGH	Security	dexie-storage importAll() не использует safeParse — prototype pollution	Заменить JSON.parse на safeParse во всех 7 методах
3	HIGH	Logic	main.tsx runtime.start() без .catch() — UI зависает при ошибке	Добавить .catch() с setReady(true) и error display
4	HIGH	Logic	countMismatches: неверные имена свойств — возвращает неправильный результат	state.state → state.status, state.failures → state.failureCount
5	HIGH	Type	RoleSandbox.tsx: messages as never — обходит типизацию	Заменить на as AdapterMessage[] (как в AgentWizard)
6	HIGH	UX	Skip-nav ссылка нерабочая — нет id="main-content" на	Добавить id="main-content" к в App.tsx
7	HIGH	UX	AgentWizard без focus trap — Tab уходит за модальку (WCAG 4.1.2)	Добавить FocusTrap/useFocusTrap в модальку
8	HIGH	Type	3 события не в EventMap — as any (scheduler:heartbeat, metrics:key-store-gauges)	Добавить события в EventMap и EVENTS
9	MEDIUM	Build	/proxy/fetch отсутствует в nginx — tool-execution получит 403 в Docker	Добавить location /proxy/fetch/ или cors-proxy сервис
10	MEDIUM	Build	Нет CI/CD — все шаги ручные, регрессии не ловятся	GitHub Actions: lint + build + test

8. Category Scorecard

Category	Original	Fixed	Partial	Still	New	Net Remaining
Security	15	8	4	3	6	13
Type Safety	14	3	6	5	7	18
Logic Bugs	17	10	2	5	2	9
Build/Deploy	16	10	1	5	4	10
UX/Accessibility	22	6	6	8	10	24
TOTAL	84	37	19	26	29	74

Progress Visualization

[illegible]

9. Positive Observations

Значимые улучшения по сравнению с первоначальным аудитом:

- CSP усилена: `wasn-unsafe-eval` вместо `unsafe-eval` — XSS через `script injection` теперь блокируется
- API-ключи защищены: `IndexedDB` вместо `localStorage`, немедленная очистка `migration`-следов
- `DOMPurify` добавлен: `dangerouslySetInnerHTML` теперь санитизируется перед рендерингом
- `Prototype pollution` защищён: `safeParse()` с `reviver` в `sqlite-storage.ts`
- `TypeScript strict mode`: `strict: true`, `strictNullChecks`, `noImplicitAny` включены
- `Vite production build`: `code-splitting`, `sourcemap:false`, `manualChunks` настроены
- `Nginx security`: `server_tokens off`, `streaming timeouts`, `catch-all deny`, `HSTS`, `X-XSS-Protection`
- `i18n ru.ts` полон: 73+ ключей добавлены для `pressure_map`, `pricing`, `system_health`
- FOIT устранён: `inline script` в `index.html` применяет тему до `React mount`
- `BudgetPanel` локализован: `Intl.NumberFormat` с поддержкой `ru-RU/en-US`
- `ErrorBoundary` локализован: все строки через `t()`, `role="alert"`, `aria-live`
- Все `CRITICAL` исправлены: 0 критических проблем из первоначальных 13